

ROAD TO HALL OF FAME

ACTIVIDAD 11

FILE PATH TRAVERSAL

Validation of Start of Path

PORTSWIGGER WEB SECURITY ACADEMY // BURP SUITE

ESTUDIANTE	Bruno Luna / Paclonk D. Mei
INSTITUCION	Universidad Politecnica de San Luis Potosi
MATERIA	CNO IV - Seguridad Informatica
ESTADO	LABORATORIO RESUELTO

DOCUMENTACION ACADEMICA DE LABORATORIO AUTORIZADO

01

DATOS DEL LABORATORIO // LAB PARAMETERS

CATEGORIA	Path Traversal
HERRAMIENTA PRINCIPAL	Burp Suite
MODULOS UTILIZADOS	Proxy + Repeater
VECTOR OBSERVADO	Parametro filename
TIPO DE VALIDACION	Prefijo de ruta permitido
ESTADO FINAL	Solved

Contexto. La actividad corresponde a un laboratorio de PortSwigger Web Security Academy realizado dentro de un entorno controlado y autorizado. El ejercicio analiza una variante de file path traversal en la que la aplicacion recibe una ruta completa para localizar imagenes y verifica que el valor proporcionado comience con un directorio considerado valido.

02

OBJETIVO // VULNERABILITY CONTEXT

El objetivo del laboratorio consiste en demostrar que una validacion basada unicamente en el inicio de una ruta no garantiza que el destino final permanezca dentro del directorio autorizado. En la aplicacion, el parametro filename debe comenzar con /var/www/images/, pero la ruta puede resolverse fuera de ese directorio cuando se introducen secuencias de recorrido posteriores al prefijo permitido.

OBJETIVO TECNICO // Comprobar la lectura controlada de /etc/passwd mediante una ruta que conserve el prefijo esperado.

03

PROCEDIMIENTO REALIZADO // RESOLUTION PATH**STEP_01 // IDENTIFICACION DE LA SOLICITUD**

Desde Burp Suite identificamos una peticion utilizada por la aplicacion para cargar una imagen de producto. En el parametro filename observamos que la aplicacion trabaja con una ruta completa cuyo inicio corresponde al directorio /var/www/images/. Esta observacion nos permite reconocer que existe una validacion de prefijo antes de acceder al sistema de archivos.

STEP_02A // DIRECT PATH TEST

Enviamos la solicitud a Repeater y realizamos primero una prueba directa con la ruta del archivo objetivo. El servidor responde con 400 Bad Request, lo que confirma que la aplicacion rechaza valores que no comienzan con el directorio esperado. Esta respuesta sirve como evidencia de que el filtro existe, aunque todavia no sabemos si valida la ruta final de manera segura.

STEP_02B-03 // PREFIX BYPASS

A continuacion modificamos filename conservando el prefijo permitido y agregando despues el recorrido necesario hacia el archivo objetivo. En el reporte no incluimos la cadena completa del payload; la representamos como /var/www/images/../../../../etc/passwd. Al reenviar la solicitud, el servidor devuelve HTTP/1.1 200 OK y muestra el contenido de /etc/passwd, confirmando que la comprobacion del inicio de la cadena puede superarse.

GET /image?filename=/var/www/images/../../../../etc/passwd/1.1

FINAL // VALIDATION

Finalmente regresamos al laboratorio de PortSwigger y verificamos que el ejercicio quede marcado como Solved. Con esto confirmamos que la condicion solicitada por el laboratorio fue alcanzada correctamente dentro del entorno autorizado.

04

REGISTRO DE EVIDENCIAS // BURP SUITE CAPTURES

Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extender

Project options User options Learn

Intercept HTTP history WebSockets history Options

Filter: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited	Status
1624	https://0a70a02904586988c:077...	GET	/academyLabHeader			
1623	https://0a70a02904586988c:077...	GET	/resources/labheader/images/ps-lab-not...			200
1622	https://0a70a02904586988c:077...	GET	/resources/labheader/images/logoAcade...			200
1619	https://0a70a02904586988c:077...	GET	/image?filename=/var/www/images/67.j...		✓	
1617	https://0a70a02904586988c:077...	GET	/image?filename=/var/www/images/17.j...		✓	
1616	https://0a70a02904586988c:077...	GET	/image?filename=/var/www/images/56.j...		✓	
1596	https://0a70a02904586988c:077...	GET	/resources/images/shop.svg			200
1594	https://0a70a02904586988c:077...	GET	/resources/labheader/js/labHeader.js			200
1592	https://0a70a02904586988c:077...	GET	/			200
1591	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json&key=Al...	✓		
1589	https://ports.wigger.net	POST	/academy?filename=/var/www/images/17.j...	✓		302
1588	https://play.google.com	POST	/log?format=json&hasfast=true&auths...	✓		200
1587	https://play.google.com	POST	/log?format=json&hasfast=true&auths...	✓		200

Request
Pretty Raw Hex

```

1 GET /image?filename=/var/www/images/67.jpg HTTP/1.1
2 Host: 0a70a02904586988c:0774ae081003b.web-security-academy.net
3 Cookie: sessionJ1TCZj64DPtMYPRae7v2Jg3EU1W5k
4 Sec-Ch-Ua: "Chromium";v="105";, "NotA;Brand";v="8"
5 Sec-Ch-Ua-Mobile?v=0
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/105.0.5195.102 Safari/537.36
7 Sec-Ch-Ua-Platform: "Linux"
8 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: no-cors
          
```

0 matches

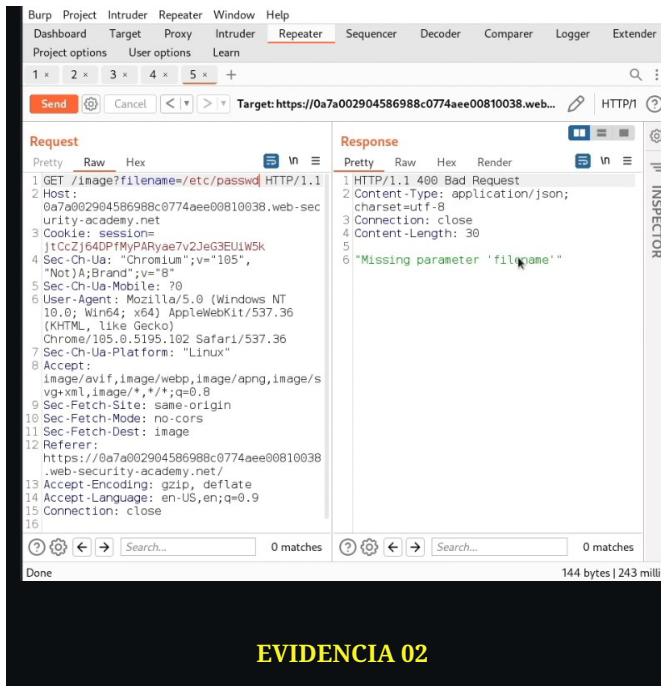
EVIDENCIA 01

HTTP History / solicitud original

Se identifica el endpoint de imagen y el parametro filename con una ruta ubicada dentro de /var/www/images/.

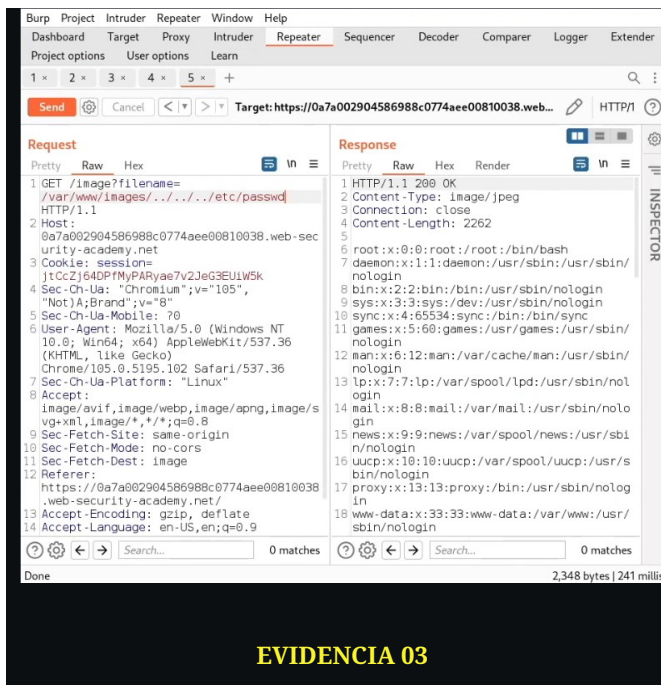
Prueba directa rechazada

Burp Repeater muestra la prueba directa contra el archivo objetivo y la respuesta 400 Bad Request.



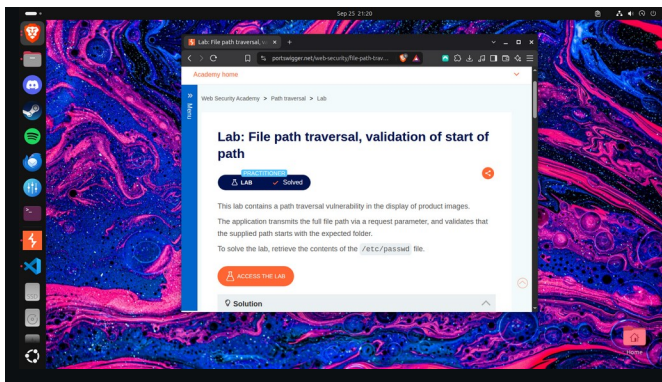
Validacion de prefijo superada

La solicitud modificada conserva el prefijo permitido y obtiene HTTP/1.1 200 OK junto con el contenido de `/etc/passwd`. El valor sensible se representa como `/var/www/images/../../etc/passwd`.



Laboratorio resuelto

PortSwigger Web Security Academy muestra el estado Solved para la actividad.



EVIDENCIA 04

Nota de integridad documental: las capturas originales se conservan en el portafolio web. Este reporte registra su funcion y resultado sin sustituirlas por imagenes ajenas al laboratorio realizado.

05**ANALISIS TECNICO** // WHY THE BYPASS WORKS**01 // VALIDACION SUPERFICIAL DEL PREFIJO**

La aplicacion comprueba que la cadena comience con el directorio permitido, pero esa condicion solo analiza la representacion inicial del valor. No demuestra que la ruta final siga contenida en ese directorio.

02 // NORMALIZACION DE LA RUTA

Cuando el sistema de archivos resuelve la ruta, las secuencias de recorrido pueden cambiar el destino real. Por ello, una cadena aparentemente valida puede terminar apuntando a un archivo localizado fuera del directorio de imagenes.

03 // IMPACTO POTENCIAL

Una validacion de este tipo puede permitir la lectura de archivos locales accesibles para el proceso web. El impacto depende de los permisos del servicio y de los archivos disponibles en el sistema.

04 // MITIGACION

La aplicacion debe canonicalizar la ruta antes de autorizarla y comprobar que el destino final permanezca dentro del directorio permitido. Cuando sea posible, resulta preferible trabajar con identificadores o nombres de archivo previamente autorizados en lugar de aceptar rutas arbitrarias.

06**RESULTADOS** // VALIDATION SUMMARY

PRUEBA	RESPUESTA	INTERPRETACION
Ruta directa al archivo objetivo	400 Bad Request	La validacion del prefijo rechaza valores que no empiezan con el directorio autorizado.
Prefijo permitido + recorrido	200 OK	La entrada supera la comprobacion inicial y la ruta termina resolviendose fuera del directorio esperado.
Validacion final en PortSwigger	Solved	El laboratorio reconoce que la condicion requerida fue completada correctamente.

07**CONCLUSION** // LEARNING OUTCOME

Con esta actividad comprobamos que validar solamente el inicio de una ruta no es suficiente para proteger un mecanismo de acceso a archivos. Aunque la aplicacion obliga a que filename comience con /var/www/images/, la ruta final puede cambiar despues de que el sistema interprete las secuencias de recorrido. La practica nos permitio relacionar el comportamiento observado en Burp Suite con la causa tecnica de la vulnerabilidad y comprender por que la canonicalizacion y la validacion del destino final son controles necesarios.

Tambien confirmamos la importancia de documentar cada fase del laboratorio: primero identificamos el comportamiento normal, despues comprobamos el rechazo de una ruta directa, posteriormente verificamos la debilidad de la validacion del prefijo y finalmente registramos el estado Solved. De esta forma, la evidencia mantiene una secuencia clara y reproducible dentro del entorno academico autorizado.

08**FUENTE CONSULTADA** // REFERENCE

PortSwigger Web Security Academy. Lab: File path traversal, validation of start of path.
<https://portswigger.net/web-security/file-path-traversal/lab-validate-start-of-path>

LAB STATUS // SOLVED | ACTIVITY 11 // ARCHIVED | NET===TECH